

비밀번호를 없애고 패스키로 잠갔습니다

T08 · 내 소개 페이지에 패스키 달기
최종 제출 문서 — 판정 체크리스트와 증거

판정	47 / 47 충족
자동 테스트	50개 통과
비밀번호 입력 칸	0개
실기기 확인	2026-09-11 · 안드로이드 크롬

결과물	https://t08-passkey-portfolio.vercel.app
소스	https://github.com/myeongjundev/t08-passkey-portfolio

이 문서의 계정과 비공개 내용은 모두 과제 확인용으로 만들어 넣은 합성 데이터입니다. 실제 개인정보는 들어 있지 않으며, challenge-서명·쿠키·세션 ID·CSRF 값과 개인키는 기록하지 않았습니다.

2026-09-11 · [myeongjundev](#)

한 장으로 보는 결과

공개 소개는 누구나 볼 수 있고, 비공개 자리는 패스키를 가진 기기만 엽니다. 비밀번호는 어디에도 없습니다.

개인키

기기를 떠나지 않습니다. 서버는 공개키·credential ID·sign counter만 저장합니다.

질문(challenge)

서버가 만들고 서버가 들고 있다가, 한 번 쓰면 버립니다. 재사용은 거절됩니다.

잠금 해제

기기의 지문 인증입니다. 지문 데이터는 서버로 오지 않고 생체정보는 저장되지 않습니다.

사람을 알아보는 값

JWT가 아니라 서버의 HttpSession입니다. 로그아웃하면 즉시 무효화됩니다.

기기 분실 대비

패스키를 두 개 등록할 수 있고, 마지막 하나는 지워지지 않습니다.

계정 사이 격리

URL의 accountId를 소유권 입력으로 쓰지 않고 세션의 account ID만 씁니다.

짧은 확인 방법

01 어디로 가나요

결과물 URL의 공개 소개 첫 화면에서 "나만의 공간"으로 이동합니다.

02 세 단계 안에 무엇을 하나요

합성 이름 입력 → 패스키 만들기(기기 지문 인증) → 비공개 자료 3건 확인.

03 무엇이 보이면 통과인가요

지문 인증 창이 뜨고, 통과 후 패스키 이름·등록일·저장 위치와 합성 비공개 자료가 보입니다.

04 안 될 때는 무엇이 보이나요

취소·검증 실패 안내, 또는 미인증 요청의 401 응답이 보입니다.

AI와 내 판단

01 AI에게 맡긴 일

요구사항 정리, WebAuthn 연결 초안, 자동화 테스트와 증거 문서 작성.

02 내가 직접 판단한 일

비밀번호 없는 공개 등록, 서버 세션, 마지막 패스키 삭제 금지, 합성 데이터 정책.

03 따르지 않은 제안

T07의 비밀번호·JWT 방식을 재사용하지 않았습니다. T08은 개인키가 기기를 떠나지 않는 패스키 과제이기 때문입니다.

판정 체크리스트 47개

과제 카드의 기준 문장을 그대로 옮기고, 각 항목의 상태와 증거 파일을 붙였습니다. 미완 항목은 없습니다.

카드 1 · 공개와 비공개를 가른다

6 / 6

V	C13	공개 영역과 비공개 영역이 화면에서 구분되어 보인다.	01-public-private-boundary.md
V	C14	비공개 영역에 들어 있는 항목이 세 개 이상이다.	01-public-private-boundary.md
V	C15	패스키로 들어가지 않은 상태에서는 비공개 영역의 내용이 화면에 보이지 않는다.	01-public-private-boundary.md
V	C16	패스키로 들어가지 않은 상태에서 비공개 자료를 서버에 직접 요청하면 거절된다.	01-public-private-boundary.md
V	C17	그 거절이 401 또는 403으로 이루어진다.	01-public-private-boundary.md
V	C18	로그인하지 않은 상태로 받은 페이지의 소스 어디에도 비공개 내용이 들어 있지 않다.	01-public-private-boundary.md

카드 2 · 패스키를 등록한다

8 / 8

V	C19	서버가 등록용 질문(challenge)을 만들어 보내고, 그 값을 서버가 확인할 때까지 보관한다.	03-server-held-ceremony.md 04-registration-options-http.md 05-registration-finish.md
V	C20	등록 요청마다 질문 값이 서로 다르다는 기록이 제출문에 있다.	04-registration-options-http.md
V	C21	등록이 끝나면 서버에 공개키가 저장된다.	05-registration-finish.md
V	C22	서버에 저장된 값이 제출문에 있고, 그 값이 공개키이며 비밀번호가 아니라는 설명이 함께 적혀 있다.	05-registration-finish.md
V	C23	개인키가 서버로 전송되지 않는다는 사실, 등록 요청 본문을 적은 기록으로 확인된다.	05-registration-finish.md
V	C24	등록한 패스키에 사람이 알아볼 수 있는 이름이 붙는다.	05-registration-finish.md
V	C25	등록을 중간에 취소하면 화면에 안내가 나오고, 서버에 아무것도 저장되지 않는다.	05-registration-finish.md
V	C26	패스키를 저장한 곳이 어디인지(구글 비밀번호 관리자·기기 자체·보안 키 중 무엇인지)가 제출문에 적혀 있다.	T08-SUBMISSION.md 12-real-device-registration.md

판정 체크리스트 (이어서)

카드 3 · 패스키로 들어간다

9 / 9

V C27	로그인할 때도 서버가 매번 새 질문을 만들어 보낸다.	06-passkey-authentication.md
V C28	로그인 요청마다 질문 값이 서로 다르다는 기록이 제출문에 있다.	06-passkey-authentication.md
V C29	서버가 저장해 둔 공개키로 서명을 확인한 뒤에만 통과시킨다.	06-passkey-authentication.md
V C30	서명 확인에 성공한 요청과 실패한 요청이 나란히 적혀 있다.	06-passkey-authentication.md
V C31	이미 한 번 쓴 질문으로 다시 로그인하려는 요청과 그 거절 응답이 적혀 있다.	06-passkey-authentication.md
V C32	로그인 뒤 무엇으로 사람을 알아보는지(세션·토큰 중 무엇인지)가 제출문에 적혀 있다.	06-passkey-authentication.md
V C33	로그아웃한 뒤 같은 값으로 다시 요청했을 때의 거절 응답이 적혀 있다.	06-passkey-authentication.md
V C34	적어 둔 기록에서 세션·토큰 값이 가려져 있다.	06-passkey-authentication.md
V C35	제출물 어디에도 비밀번호를 입력하는 칸이 없다.	01-public-private-boundary.md 06-passkey-authentication.md

카드 4 · 기기를 잃어버렸을 때

5 / 5

V C42	한 계정에 패스키가 두 개 등록되어 있다.	07-second-passkey-recovery.md
V C43	등록된 패스키 목록을 화면에서 볼 수 있고, 각각의 이름과 등록한 날짜가 보인다.	07-second-passkey-recovery.md
V C44	패스키 하나를 지운 뒤 남은 하나로 들어갈 수 있다.	07-second-passkey-recovery.md
V C45	지운 패스키로는 더 이상 들어갈 수 없다는 기록이 적혀 있다.	07-second-passkey-recovery.md
V C46	패스키가 하나도 남지 않았을 때 어떻게 되는지가 화면과 제출문에 적혀 있다.	07-second-passkey-recovery.md

카드 5 · 확인하고 설명서를 쓴다

19 / 19

V C01	결과물 URL 필드에 HTTPS URL 한 개가 제출되어 있다.	11-production-startup.md T08-SUBMISSION.md
V C02	소스 URL 필드에 HTTPS URL 한 개가 제출되어 있다.	09-public-source-and-deployment-readiness.md T08-SUBMISSION.md
V C03	제출한 모든 URL(결과물·소스)은 계정 생성·로그인·인증·초대·비밀번호·OAuth·CAPTCHA 없이 새 시크릿 창에서 열린다.	09-public-source-and-deployment-readiness.md 11-production-startup.md

판정 체크리스트 (이어서)

카드 5 · 확인하고 설명서를 쓴다

19 / 19

	C10	결과물 주소의 첫 화면은 공개 소개 페이지이고, 심사하는 사람이 아무것도 등록하지 않아도 열린다.	11-production-startup.md
	C11	1번 과제에서 만든 소개 페이지에 이어 붙였고, 1번의 공개 내용이 그대로 남아 있다.	01-public-private-boundary.md 11-production-startup.md
	C12	제출물에 실제 개인정보가 없고, 넣은 내용이 만들어 넣은 것이라는 사실이 적혀 있다.	01-public-private-boundary.md T08-SUBMISSION.md
	C36	패스키를 등록한 계정이 두 개이고, 각각에 서로 다른 비공개 내용이 들어 있다.	08-cross-account-isolation.md
	C37	한쪽 패스키로 들어가 다른 쪽의 비공개 자료를 읽으려는 요청과 그 거절 응답이 적혀 있다.	08-cross-account-isolation.md
	C38	반대 방향(다른 쪽에서 첫 쪽으로)의 요청도 똑같이 거절된 기록이 적혀 있다.	08-cross-account-isolation.md
	C39	거절 앞뒤로 반대편의 자료 건수가 같다는 기록이 적혀 있다.	08-cross-account-isolation.md
	C40	주소나 요청 본문에 다른 계정을 적어 보낸 요청, 그래도 내 자료만 돌아온 응답이 적혀 있다.	08-cross-account-isolation.md
	C41	위 거절을 만들어 내는 소스의 위치가 제출문에 적혀 있다.	08-cross-account-isolation.md T08-AUTH-GUIDE.md
	C47	인증 구현 설명서의 여섯 항목(① 무엇으로 붙였나, ② 왜 그걸 골랐나, ③ 어디를 어떻게 고쳤나, ④ 안 열리는 것을 확인한 기록, ⑤ AI와 나, ⑥ 아직 못 막은 것)이 각각 나뉘어 적혀 있다.	T08-AUTH-GUIDE.md
	C48	①에 직접 구현·라이브러리·인증 서비스 중 무엇을 썼는지와 그 이름이 적혀 있다.	T08-AUTH-GUIDE.md
	C49	③에 등록·로그인·로그아웃·비공개 자료 조회 네 흐름이 소스의 어디를 지나는지 적혀 있다.	T08-AUTH-GUIDE.md
	C50	④에 확인 네 가지(로그인 없이 열기, 남의 패스키로 열기, 이미 쓴 질문 재사용, 패스키 삭제 뒤 로그인)가 모두 있고, 각각 성공한 요청과 거절된 요청이 나란히 적혀 있다.	T08-AUTH-GUIDE.md
	C51	⑥에 아직 못 막은 것이 최소 하나 구체적으로 적혀 있다. 없다고만 적으면 통과하지 않는다.	T08-AUTH-GUIDE.md
	C52	짧은 확인 방법에 ① 어디로 가나요, ② 세 단계 안에 무엇을 하나요, ③ 무엇이 보이면 통과인가요, ④ 안 될 때는 무엇이 보이나요가 각각 나뉘어 적혀 있다.	T08-SUBMISSION.md

판정 체크리스트 (이어서)

카드 5 · 확인하고 설명서를 쓴다

19 / 19

V

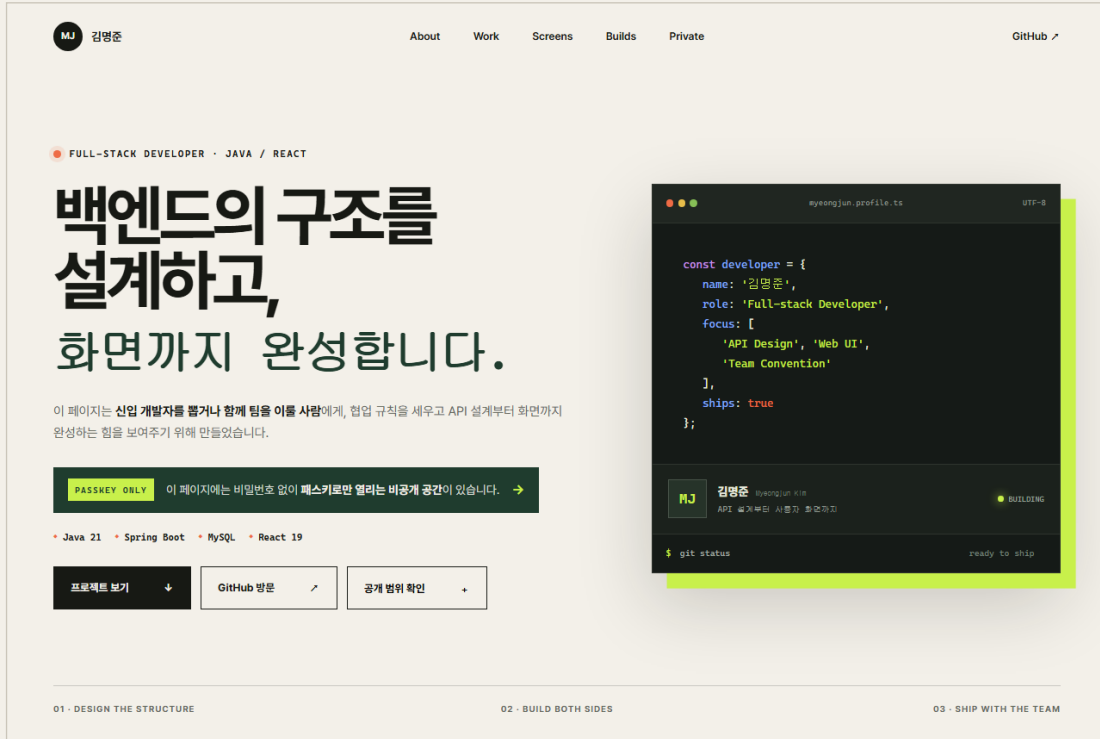
C53

제출문에 ① AI에게 맡긴 일, ② 내가 직접 판단한 일, ③ AI 제안을 따르지 않은 일(없다면 왜 없었는지)이 각각 나뉘어 적혀 있다.

T08-SUBMISSION.md

공개는 어디까지인가

첫 화면은 등록 없이 열리는 공개 소개입니다. T01에서 만든 소개가 그대로 남아 있고, 잠긴 자리가 있다는 사실은 첫 화면에서 바로 보입니다.



공개 소개 첫 화면. 소개 문장 바로 아래의 PASSKEY ONLY 띠가 비공개 자리로 가는 입구입니다. 패스키가 이 과제의 본체라 입구를 첫 화면으로 올렸고, 공개 내용이 끝나는 자리의 05 섹션은 그대로 두었습니다.



공개 내용이 끝나는 자리. “공개 소개는 여기까지, 그다음은 패스키로.” 경계를 화면에서 한 번 더 굽습니다.

정말 잠겨 있는지, 요청과 응답으로

막았다는 말 대신 실제 응답을 냅니다. 아래는 프로덕션에서 그대로 받은 기록입니다.

미인증으로 비공개 페이지를 직접 열면

```
$ curl -i https://t08-passkey-portfolio.vercel.app/private

HTTP/1.1 401 Unauthorized
Cache-Control: no-store
Content-Type: application/json; charset=UTF-8

{"error": "passkey_session_required"}
```

미인증으로 비공개 API를 직접 부르면

```
$ curl -i https://t08-passkey-portfolio.vercel.app/api/private-items

HTTP/1.1 401 Unauthorized
Cache-Control: no-store
Content-Type: application/json; charset=UTF-8

{"error": "passkey_session_required"}
```

공개 첫 화면은 열고, 비공개 내용은 본문에 없다

```
$ curl -s -o /dev/null -w '%{http_code}' .../
200

$ curl -s .../ | grep -cE
'합성 프로젝트|합성 지원 기업|합성 주간 회고'
0
```

거절은 401입니다. 화면에서만 감춘 것이 아니라 서버가 내려 주지 않습니다. 미인증 상태로 받은 첫 화면의 소스 어디에도 비공개 항목의 제목이 들어 있지 않습니다.

이 요청들은 세션과 CSRF 토큰이 애초에 발급되지 않은 상태의 것이라, 가릴 비밀값이 없습니다.

등록할 때 무엇이 오거나

서버가 질문을 만들고, 기기가 열쇠 한 쌍을 만들어 공개키만 돌려줍니다. 개인키는 기기를 떠나지 않습니다.

01

서버가 질문을 만든다

요청마다 다른 난수 challenge를 만들고, 확인할 때까지 서버가 보관합니다.

02

기기가 열쇠 한 쌍을 만든다

개인키는 기기의 보안 하드웨어에 남고 밖으로 나오지 않습니다.

03

공개키와 서명만 서버로 간다

등록 요청 본문에 개인키는 없습니다. 공개키·credential ID·서명뿐입니다.

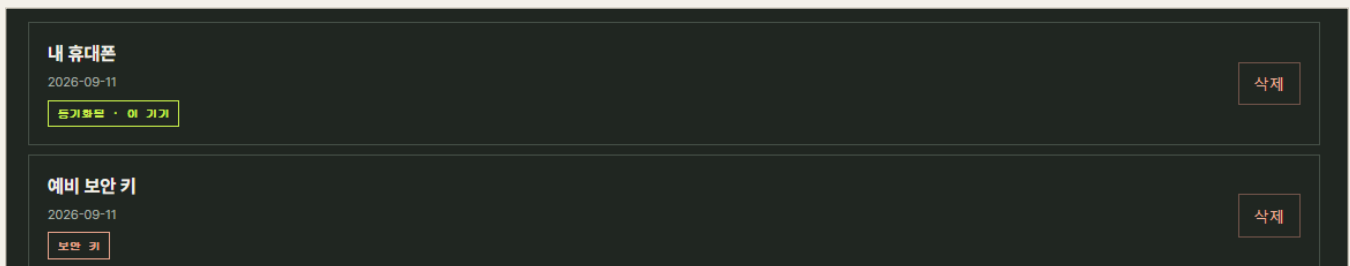
04

서버가 확인하고 저장한다

쓴 질문은 버려집니다. 저장되는 값은 공개키이지 비밀번호가 아닙니다.

저장 위치를 화면이 말합니다

등록 응답이 주는 backupEligible과 transports를 그대로 옮겨 목록에 표시합니다. 어디에 저장됐는지 확인하려고 기기 설정을 열 필요가 없습니다. 두 값 모두 인증기를 설명하는 값이지 키가 아니므로 비밀이 아닙니다.



동기화됨 — 구글 계정에 백업됩니다. 기기를 바꿔도 따라옵니다.

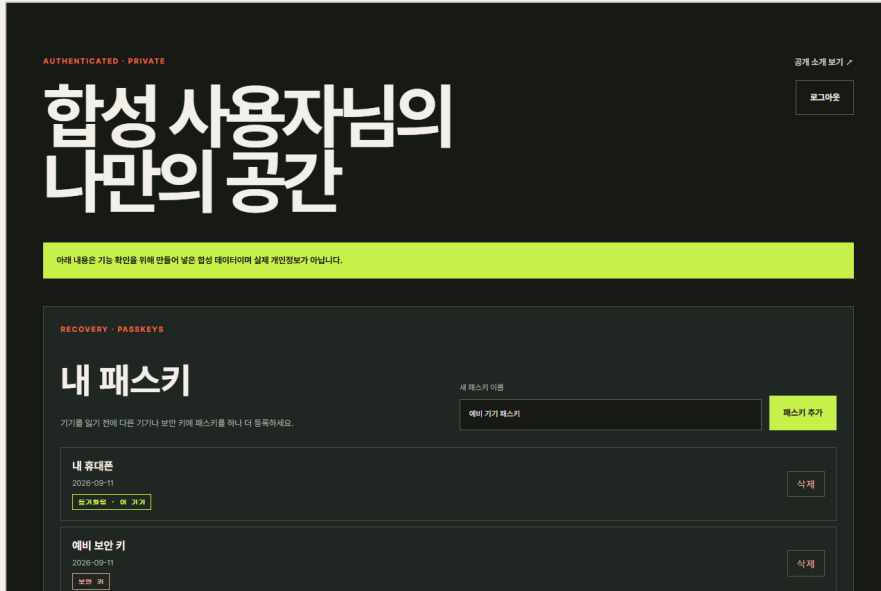
이 기기 / 보안 키 — 어디서 만들어졌는지. 두 패스키를 구분할 근거가 됩니다.

실기기 확인 — 2026-09-11 · 안드로이드 크롬에서 등록한 패스키는 Google 비밀번호 관리자에 저장되었습니다. 기기 자체도 보안 키도 아닙니다. 목록의 “동기화됨 · 이 기기” 배지와 등록·로그인 때 뜨는 Google 비밀번호 관리자 창이 같은 것을 가리킵니다. (T08-C26)

실제로 동작하는 순서

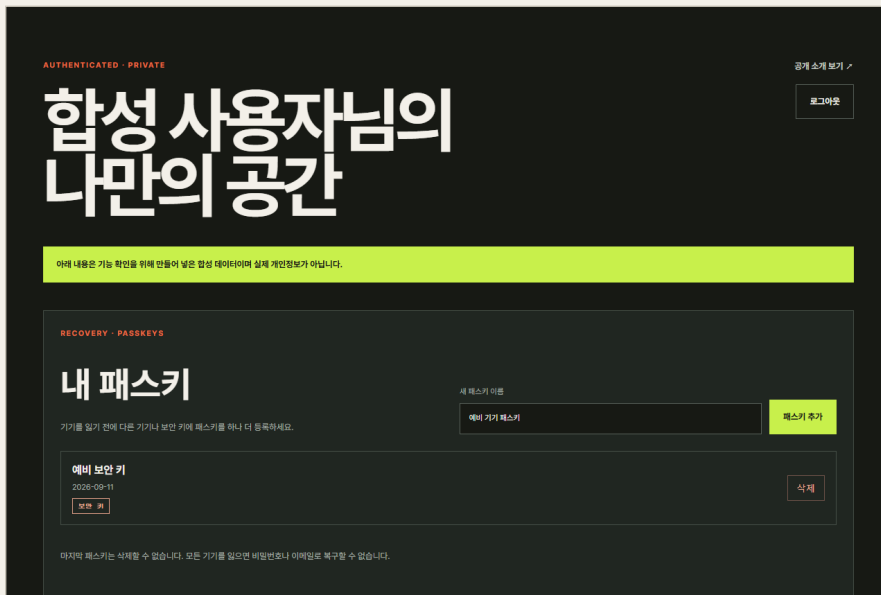
패스키 두 개를 등록하고, 하나를 지운 뒤 남은 하나로 들어갑니다. 마지막 하나는 지워지지 않습니다.

1. 패스키 두 개를 등록했습니다



내 휴대폰(동기화됨 · 이 기기)과 예비 보안 키(보안 키). 이름·등록일·저장 위치가 모두 보입니다.

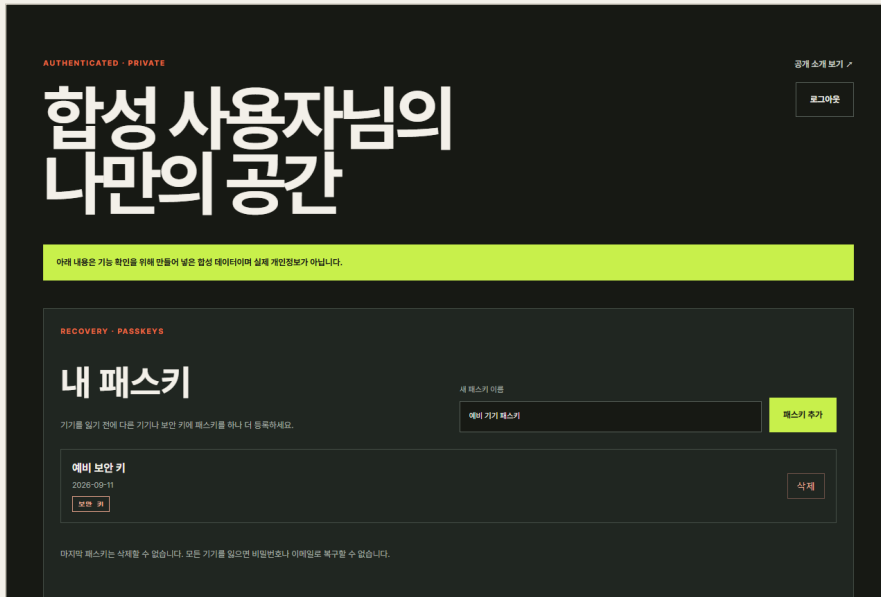
2. 하나를 지웠습니다



내 휴대폰을 삭제했습니다. 지운 패스키로는 더 이상 들어갈 수 없습니다.

실제로 동작하는 순서 (이어서)

3. 남은 하나로 들어갔습니다



예비 보안 키로 로그인해 비공개 자리가 그대로 열립니다.

마지막 패스키는 지워지지 않습니다

하나까지 지울 수 있으면 그 순간 계정을 되찾을 방법이 사라집니다. 이 시스템에는 비밀번호도 이메일 복구도 없습니다.

예비 보안 키

2026-09-11

보안 키

삭제

마지막 패스키는 삭제할 수 없습니다. 모든 기기를 잃으면 비밀번호나 이메일로 복구할 수 없습니다.

마지막 패스키는 삭제할 수 없습니다. 먼저 다른 패스키를 등록하세요.

HTTP 409 · final_passkey_required

화면에는 “마지막 패스키는 삭제할 수 없습니다. 먼저 다른 패스키를 등록하세요.”가 나옵니다.

안 열리는 것을 확인한 네 가지

로그인 없이 열기	통과 인증 세션의 조회 → 200, 3건 거절 무세션 요청 → 401	01-public-private-boundary
남의 패스키로 열기	통과 A 패스키로 A 자료 → 200 거절 A→B와 B→A → 동일한 404	08-cross-account-isolation
이미 쓴 질문 재사용	통과 최초 검증된 assertion → 200 거절 같은 질문 재사용 → 400	06-passkey-authentication
삭제한 패스키로 로그인	통과 남은 예비 키 → 성공 거절 지운 기기 키 → 거절	07-second-passkey-recovery

아직 못 막은 것

없다고 적지 않았습니니다. 실기기에서 관측한 것까지 그대로 남깁니다.

- **공개 등록에 초대·승인이 없습니다**

누구나 계정을 만들 수 있어 자동 계정 생성을 악용할 수 있습니다.

- **모든 패스키 기기를 잃으면 복구가 없습니다**

비밀번호도 이메일 복구도 없으므로 계정을 되찾을 수 없습니다. 그래서 마지막 하나의 삭제제를 막았습니다.

- **sign counter가 늘 0이면 복제를 알기 어렵습니다**

동기화형 패스키는 counter를 0으로 보고하는 경우가 있어 복제 의심 신호를 얻기 어렵습니다.

- **세션 저장소가 멈추면 비공개 접근도 실패합니다**

로그인 상태를 확인할 수 없을 때 추측하거나 우회하지 않고 실패하는 쪽으로 동작합니다.

- **등록 직후 첫 요청이 간헐적으로 500이 됩니다**

2026-09-11 실물 휴대폰 등록에서 한 번 관측했습니다. 새로고침하면 열리고 등록은 이미 커밋된 뒤라 데이터는 정상이지만, 원인은 확정하지 못했습니다.

마지막 항목에 대해

원인을 확정하지 못했으므로 고쳤다고 적지 않았습니니다. 지금 대응은 원인 제거가 아니라, 같은 일이 다시 나도 뵈을 수 있는 화면을 주는 데까지입니다. 에러 화면이 없어 Spring 기본 페이지가 그대로 나오던 것을 페이지 톤에 맞는 안내와 새로고침 버튼으로 바꿨고, 응답에 서버 내부 정보가 실리지 않도록 네 가지 설정을 고정했습니다. 미인증 거절이 여전히 401 JSON인 것도 테스트로 묶었습니다. 기록은 docs/evidence/12-real-device-registration.md에 있습니다.

설명서 여섯 항목은 어디에 있나

- | | |
|-------------------|--|
| ① 무엇으로 붙였나 | WebAuthn4J 0.31.8 + Spring Boot 4.1.1, 서버 세션, 기기 지문 인증 |
| ② 왜 그걸 골랐나 | 검증은 라이브러리에 맡기고 challenge 수명·소유권·세션을 애플리케이션이 담당 |
| ③ 어디를 어떻게 고쳤나 | 등록·로그인·로그아웃·비공개 조회 네 흐름이 지나는 소스 위치 |
| ④ 안 열리는 것을 확인한 기록 | 확인 네 가지의 통과·거절 대조표 |
| ⑤ AI와 나 | 맡긴 일과 직접 판단한 일, 따르지 않은 제안 |
| ⑥ 아직 못 막은 것 | 이 쪽에 옮겨 적은 다섯 가지 |

전문은 소스 저장소의 docs/T08-AUTH-GUIDE.md에 있습니다.